

## Initial Post

by Séba Daher - Tuesday, 2 June 2026, 4:53 AM

(Evidence: <https://www.my-course.co.uk/mod/forum/discuss.php?d=368806#p743987>)

The central criticism advanced by Wunder et al. (2024) is that CVSSv3.1 fails to deliver the scoring consistency it promises. Their survey of 196 practitioners found that the metrics Attack Vector, User Interaction and Scope were assessed inconsistently for widespread vulnerability types, and that 68% of participants in a follow-up study assigned a different severity to the same vulnerability nine months later. The authors further fault the dispersal of guidance across three separate documents, around 30% of which users had never read, and the routine misapplication of CVSS to security deficiencies that cannot be exploited directly. A deeper criticism, drawn from Spring et al. (2018), is that the scoring formula is neither empirically nor theoretically justified, and that organisations frequently treat the Base Score as a risk rating when FIRST intends it only as a measure of severity.

This critique is persuasive. Treating severity as risk ignores threat likelihood and asset context, which the contemporary framing of risk as a function of consequence and uncertainty explicitly demands (Aven and Thekdi, 2025). Deriving a precise decimal from ordinal judgements also lends a misleading air of objectivity to an assessment that remains subjective, a concern echoed by participants who saw the scoring as supplying a veneer of objectivity over what is essentially a subjective opinion (Wunder et al., 2024).

Of the alternatives the authors note, the Stakeholder-Specific Vulnerability Categorization (SSVC) presents the strongest case for replacement (Spring et al., 2020). Rather than computing a number, SSVC routes the evaluator through decision points such as exploitation status, exposure and mission impact, and outputs an actionable category ranging from defer to immediate. This remedies the Base Score's blindness to real-world exploitability and its conflation of severity with prioritisation. The trade-off is weaker cross-organisation comparability and continued reliance on analyst judgement at each node. On balance, an output tied to a defensible decision serves vulnerability management better than a number that practitioners themselves admit they distrust.

Would SSVC's decision-tree transparency genuinely reduce inter-rater disagreement, or simply relocate it to the decision points?

## References

Aven, T. and Thekdi, S. (2025) *Risk Science: An Introduction*. 2nd edn. Oxon: Routledge.

Spring, J., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2018) *Towards Improving CVSS*. Pittsburgh, PA: Software Engineering Institute, Carnegie Mellon University. Available at: [https://www.sei.cmu.edu/documents/574/2018\\_019\\_001\\_538372.pdf](https://www.sei.cmu.edu/documents/574/2018_019_001_538372.pdf) (Accessed: 1 June 2026).

Spring, J., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2020) '*Prioritizing vulnerability response: a stakeholder-specific vulnerability categorization (version 1.1)*', Workshop on the Economics of Information Security. Brussels, Belgium, December. Available at: <https://weis2020.econinfosec.org/wp-content/uploads/sites/8/2020/06/weis20-final6.pdf> (Accessed: 1 June 2026).